# Security Findings

TRACEGUARD | Evidence snapshot

INCOMPLETE COVERAGE: unknown checks must be investigated.

## Schema Version
1.0

## Bundle Id
31b1a622-e13d-4090-8ba7-af1c23a79690

## Generated At
2026-10-31T22:05:06.537Z

## Scan

**Id**
3557f034-3d1e-4bf8-8211-3c6b10242697

**Source**
ZIP upload

**Created At**
2026-10-31T22:04:53.126Z

**Inventory Sha256**
1260fb9550cb4445cfc71986b0c653f6dbaeba801b96d974c0e7074af071e7af

## Coverage

**Status**
partial

**Checked At**
2026-10-31T22:05:05.982Z

**Package Instances**
6

**Matched**
5

**No Known Match**
1

**Unknown**
0

**Findings Included**
5

**Findings Omitted**
0

## Limitations

**1.**
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

**2.**
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

**3.**
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

**4.**
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

**5.**
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per

finding are included. Descriptions, references, paths and source evidence are bounded.

**6.**
Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

**7.**
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

**8.**
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

**9.**
Transitive updates require changes to the owning parent or carefully reviewed root overrides. No dependency graph or lockfile is changed automatically.

**10.**
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

**11.**
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

**12.**
Python reachability is unsupported and UNKNOWN. PyPI fix candidates require an advisory fixed boundary, a published non-yanked release and a fresh OSV query; Python/platform compatibility is NOT TESTED. npm supply-chain heuristics do not assess PyPI packages.

**13.**
Dependency inventory is incomplete or has warnings; advisory coverage only applies to recorded resolved instances.

## Report Type
security-findings

## Title
Security Findings

## Findings

**1.**

**Id**
F-001

**Package**

**Id**
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

**Ecosystem**
PyPI

**Name**
pyyaml

**Version**
5.3.1

**Project**
poetry.lock

**Install Path**
poetry/pyyaml@5.3.1#0

**Is Project**
false

**Direct**
true

**Transitive**
false

**Advisory Eligible**
true

**Version Evidence**
lockfile

**What Is Wrong**
OSV returned 2 advisory ID(s) for pyyaml@5.3.1 at this installed location.

**Why It Matters**
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

**Advisories**

**1.**

**Id**
GHSA-8q59-q68h-6hv4

**Source**
https://api.osv.dev/v1/vulns/GHSA-8q59-q68h-6hv4

**Verification**
verified

**Summary**
Improper Input Validation in PyYAML

**Description**
A vulnerability was discovered in the PyYAML library in versions before 5.4, where it is susceptible to arbitrary code execution when it processes untrusted YAML files through the full_load method or with the FullLoader loader. Applications that use the library to process untrusted input may be vulnerable to this flaw. This flaw allows an attacker to execute arbitrary code on the system by abusing the python/object/new constructor. This flaw is due to an incomplete fix for CVE-2020-1747.

**Aliases**

**1.**
CVE-2020-14343

**2.**
PYSEC-2021-142

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

**2.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
5.4

**References**

**1.**
https://osv.dev/vulnerability/GHSA-8q59-q68h-6hv4

**2.**
https://nvd.nist.gov/vuln/detail/CVE-2020-14343

**3.**
https://github.com/SeldonIO/seldon-core/issues/2252

**4.**
https://github.com/yaml/pyyaml/issues/420

**5.**

https://github.com/yaml/pyyaml/issues/420#issuecomment-663673966

**6.**
https://github.com/yaml/pyyaml/commit/a001f2782501ad2d24986959f02 39a354675f9dc

**7.**
https://bugzilla.redhat.com/show_bug.cgi?id=1860466

**8.**
https://github.com/advisories/GHSA-8q59-q68h-6hv4

**9.**
https://github.com/pypa/advisory-database/tree/main/vulns/pyyaml/ PYSEC-2021-142.yaml

**10.**
https://github.com/yaml/pyyaml

**11.**
https://pypi.org/project/PyYAML

**12.**
https://www.oracle.com/security-alerts/cpuapr2022.html

**13.**
https://www.oracle.com/security-alerts/cpujul2022.html

**Modified**
2026-02-04T03:33:10.792778Z

**Severity Label**
CRITICAL

**Affected Versions**

**1.**
listed version 3.01

**2.**
listed version 3.02

**3.**
listed version 3.03

**4.**
listed version 3.04

**5.**
listed version 3.05

**6.**
listed version 3.06

**7.**
listed version 3.07

**8.**
listed version 3.08

**9.**
listed version 3.09

**10.**
listed version 3.10

**11.**
listed version 3.11

**12.**
listed version 3.12

**13.**
listed version 3.13

**14.**
listed version 3.13b1

**15.**
listed version 3.13rc1

**16.**
listed version 4.2b1

**17.**
listed version 4.2b2

**18.**
listed version 4.2b4

**19.**
listed version 5.1

**20.**
listed version 5.1.1

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"5.4"}]

**2.**

**Id**
PYSEC-2021-142

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2021-142

**Verification**
verified

**Summary**
OSV advisory matches the recorded package version.

**Description**
A vulnerability was discovered in the PyYAML library in versions before 5.4, where it is susceptible to arbitrary code execution when it processes untrusted YAML files through the full_load method or with the FullLoader loader. Applications that use the library to process untrusted input may be vulnerable to this flaw. This flaw allows an attacker to execute arbitrary code on the system by abusing the python/object/new constructor. This flaw is due to an incomplete fix for CVE-2020-1747.

**Aliases**

**1.**
CVE-2020-14343

**2.**
GHSA-8q59-q68h-6hv4

**Severity**
(none recorded)

**Fixed Versions**

**1.**
5.4

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2021-142

**2.**
https://bugzilla.redhat.com/show_bug.cgi?id=1860466

**3.**
https://github.com/advisories/GHSA-8q59-q68h-6hv4

**Modified**
2023-11-08T04:02:26.414885Z

**Affected Versions**

**1.**
listed version 3.01

**2.**
listed version 3.02

**3.**
listed version 3.03

**4.**
listed version 3.04

**5.**
listed version 3.05

**6.**
listed version 3.06

**7.**
listed version 3.07

**8.**
listed version 3.08

**9.**
listed version 3.09

**10.**
listed version 3.10

**11.**
listed version 3.11

**12.**
listed version 3.12

**13.**
listed version 3.13

**14.**
listed version 3.13b1

**15.**
listed version 3.13rc1

**16.**
listed version 4.2b1

**17.**
listed version 4.2b2

**18.**
listed version 4.2b4

**19.**
listed version 5.1

**20.**
listed version 5.1.1

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"5.4"}]

**Dependency Impact**

**Parent Count**
1

**Parents**

**1.**

**Id**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**Name**
traceguard-python-lab

**Install Path**

**Root Paths**

**1.**

**1.**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**2.**
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

**Truncated**
false

**Reachability**

**Status**
UNKNOWN

**Report**

**Status**
UNKNOWN

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Target**

**Package Node Id**
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

**Export Name**

**Mapping**
Python analysis unsupported

**Coverage**

**Entrypoints**
(none recorded)

**Analyzed Files**
(none recorded)

**Source Files Available**
0

**Skipped Sources**
(none recorded)

**Functions Visited**
0

**Calls Examined**
0

**Complete For Declared Entrypoints**
false

**Boundary**
Python/PyPI dependency inventory only; no Python source call analysis.

**Evidence**
(none recorded)

**Gaps**

**1.**

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Limitations**

**1.**
Python reachability is unsupported and remains UNKNOWN. No Python source, imports, build backend, or package scripts are executed.

**Exploitability**
NOT ASSESSED

**2.**

**Id**
F-002

**Package**

**Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Ecosystem**
PyPI

**Name**
requests

**Version**
2.31.0

**Project**
poetry.lock

**Install Path**
poetry/requests@2.31.0#1

**Is Project**
false

**Direct**
true

**Transitive**
false

**Advisory Eligible**
true

**Version Evidence**
lockfile

**What Is Wrong**
OSV returned 6 advisory ID(s) for requests@2.31.0 at this installed location.

**Why It Matters**
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

**Advisories**

**1.**

**Id**
GHSA-9hjg-9r4m-mvj7

**Source**
https://api.osv.dev/v1/vulns/GHSA-9hjg-9r4m-mvj7

**Verification**
verified

**Summary**
Requests vulnerable to .netrc credentials leak via malicious URLs

**Description**
### Impact

Due to a URL parsing issue, Requests releases prior to 2.32.4 may leak .netrc credentials to third parties for specific maliciously-crafted URLs.

### Workarounds
For older versions of Requests, use of the .netrc file can be disabled with `trust_env=False` on your Requests Session ([docs](https://requests.readthedocs.io/en/latest/api/#requests.S ession.trust_env)).

### References
https://github.com/psf/requests/pull/6965
https://seclists.org/fulldisclosure/2025/Jun/2

**Aliases**

**1.**
CVE-2024-47081

**2.**
PYSEC-2026-1872

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.32.4

**References**

**1.**
https://osv.dev/vulnerability/GHSA-9hjg-9r4m-mvj7

**2.**
https://github.com/psf/requests/security/advisories/GHSA-9hjg-9r4m-mvj7

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2024-47081

**4.**
https://github.com/psf/requests/pull/6965

**5.**
https://github.com/psf/requests/commit/96ba401c1296ab1dda74a2365e f36d88f7d144ef

**6.**
https://github.com/advisories/GHSA-9hjg-9r4m-mvj7

**7.**
https://github.com/psf/requests

**8.**
https://github.com/psf/requests/releases/tag/v2.32.4

**9.**
https://github.com/pypa/advisory-database/tree/main/vulns/request s/PYSEC-2026-1872.yaml

**10.**
https://pypi.org/project/requests

**11.**
https://requests.readthedocs.io/en/latest/api/#requests.Session.trust_env

**12.**
https://seclists.org/fulldisclosure/2025/Jun/2

**Modified**
2026-10-19T20:00:04.716114530Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**
listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**
listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.32.4"}]

**2.**

**Id**
GHSA-9wx4-h78v-vm56

**Source**
https://api.osv.dev/v1/vulns/GHSA-9wx4-h78v-vm56

**Verification**
verified

**Summary**
Requests `Session` object does not verify requests after making first request with verify=False

**Description**
When using a `requests.Session`, if the first request to a given origin is made with `verify=False`, TLS certificate verification may remain disabled for all subsequent requests to that origin, even if `verify=True` is explicitly specified later.

This occurs because the underlying connection is reused from the session's connection pool, causing the initial TLS verification setting to persist for the lifetime of the pooled connection. As a result, applications may unintentionally send requests without certificate verification, leading to potential man-in-the-middle attacks and compromised confidentiality or integrity.

This behavior affects versions of `requests` prior to 2.32.0.

**Aliases**

**1.**
CVE-2024-35195

**2.**
PYSEC-2026-1873

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:L/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:N

**Fixed Versions**

**1.**
2.32.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-9wx4-h78v-vm56

**2.**
https://github.com/psf/requests/security/advisories/GHSA-9wx4-h78v-vm56

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2024-35195

**4.**
https://github.com/psf/requests/pull/6655

**5.**
https://github.com/psf/requests/commit/a58d7f2ffb4d00b46dca2d70a3 932a0b37e22fac

**6.**
https://github.com/psf/requests

**7.**
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
IYLSNK5TL46Q6XPRVMHVWS63MVJQOK4Q

**8.**
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
N7WP6EYDSUOCOJYHDK5NX43PYZ4SNHGZ

**Modified**
2026-09-10T03:50:13.740879755Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**
listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**

listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.32.0"}]

**3.**

**Id**
GHSA-gc5v-m9x4-r6x2

**Source**
https://api.osv.dev/v1/vulns/GHSA-gc5v-m9x4-r6x2

**Verification**
verified

**Summary**
Requests has Insecure Temp File Reuse in its extract_zipped_paths() utility function

**Description**
### Impact
The `requests.utils.extract_zipped_paths()` utility function uses a predictable filename when extracting files from zip archives into the system temporary directory. If the target file already exists, it is reused without validation. A local attacker with write access to the temp directory could pre-create a malicious file that would be loaded in place of the legitimate one.

### Affected usages
**Standard usage of the Requests library is not affected by this vulnerability.** Only applications that call `extract_zipped_paths()` directly are impacted.

### Remediation
Upgrade to at least Requests 2.33.0, where the library now extracts files to a non-deterministic location.

If developers are unable to upgrade, they can set `TMPDIR` in their environment to a directory with restricted write access.

**Aliases**

**1.**
CVE-2026-25645

**2.**
PYSEC-2026-2275

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:L/AC:H/PR:L/UI:R/S:U/C:N/I:H/A:N

**Fixed Versions**

**1.**
2.33.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-gc5v-m9x4-r6x2

**2.**
https://github.com/psf/requests/security/advisories/GHSA-gc5v-m9x4-r6x2

**3.**

https://nvd.nist.gov/vuln/detail/CVE-2026-25645

**4.**
https://github.com/psf/requests/commit/66d21cb07bd6255b1280291c4f afb71803cdb3b7

**5.**
https://github.com/psf/requests

**6.**
https://github.com/psf/requests/releases/tag/v2.33.0

**Modified**
2026-09-10T03:50:39.207922076Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**
listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**
listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.33.0"}]

**4.**

**Id**
PYSEC-2026-1872

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1872

**Verification**
verified

**Summary**
Requests vulnerable to .netrc credentials leak via malicious URLs

**Description**
### Impact

Due to a URL parsing issue, Requests releases prior to 2.32.4 may leak .netrc credentials to third parties for specific maliciously-crafted URLs.

### Workarounds
For older versions of Requests, use of the .netrc file can be disabled with `trust_env=False` on your Requests Session ([docs](https://requests.readthedocs.io/en/latest/api/#requests.S ession.trust_env)).

### References
https://github.com/psf/requests/pull/6965
https://seclists.org/fulldisclosure/2025/Jun/2

**Aliases**

**1.**
CVE-2024-47081

**2.**
GHSA-9hjg-9r4m-mvj7

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.32.4

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-1872

**2.**
https://github.com/psf/requests/security/advisories/GHSA-9hjg-9r4m-mvj7

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2024-47081

**4.**
https://github.com/psf/requests/pull/6965

**5.**
https://github.com/psf/requests/commit/96ba401c1296ab1dda74a2365e f36d88f7d144ef

**6.**
https://github.com/psf/requests

**7.**
https://requests.readthedocs.io/en/latest/api/#requests.Session.trust_env

**8.**
https://seclists.org/fulldisclosure/2025/Jun/2

**9.**

https://pypi.org/project/requests

**10.**
https://github.com/advisories/GHSA-9hjg-9r4m-mvj7

**Modified**
2026-07-07T17:47:00.332079836Z

**Affected Versions**

**1.**
listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**
listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**
listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.32.4"}]

**5.**

**Id**
PYSEC-2026-1873

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1873

**Verification**

verified

**Summary**
Requests `Session` object does not verify requests after making first request with verify=False

**Description**
When using a `requests.Session`, if the first request to a given origin is made with `verify=False`, TLS certificate verification may remain disabled for all subsequent requests to that origin, even if `verify=True` is explicitly specified later.

This occurs because the underlying connection is reused from the session's connection pool, causing the initial TLS verification setting to persist for the lifetime of the pooled connection. As a result, applications may unintentionally send requests without certificate verification, leading to potential man-in-the-middle attacks and compromised confidentiality or integrity.

This behavior affects versions of `requests` prior to 2.32.0.

**Aliases**

**1.**
CVE-2024-35195

**2.**
GHSA-9wx4-h78v-vm56

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:L/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:N

**Fixed Versions**

**1.**
2.32.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-1873

**2.**
https://github.com/psf/requests/security/advisories/GHSA-9wx4-h78v-vm56

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2024-35195

**4.**
https://github.com/psf/requests/pull/6655

**5.**
https://github.com/psf/requests/commit/a58d7f2ffb4d00b46dca2d70a3 932a0b37e22fac

**6.**
https://github.com/psf/requests

**7.**
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
IYLSNK5TL46Q6XPRVMHVWS63MVJQOK4Q

**8.**
https://lists.fedoraproject.org/archives/list/package-announce@li sts.fedoraproject.org/message/
N7WP6EYDSUOCOJYHDK5NX43PYZ4SNHGZ

**9.**
https://pypi.org/project/requests

**10.**
https://github.com/advisories/GHSA-9wx4-h78v-vm56

**Modified**
2026-07-07T17:46:36.762141019Z

**Affected Versions**

**1.**

listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**
listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**
listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.32.0"}]

**6.**

**Id**
PYSEC-2026-2275

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-2275

**Verification**
verified

**Summary**
OSV advisory matches the recorded package version.

**Description**
Requests is a HTTP library. Prior to version 2.33.0, the `requests.utils.extract_zipped_paths()` utility function uses a predictable filename when extracting files from zip archives into the system temporary directory. If the target file already exists, it is reused without validation. A local attacker with write access to the temp directory could pre-create a malicious file

that would be loaded in place of the legitimate one. Standard usage of the Requests library is not affected by this vulnerability. Only applications that call `extract_zipped_paths()` directly are impacted. Starting in version 2.33.0, the library extracts files to a non-deterministic location. If developers are unable to upgrade, they can set `TMPDIR` in their environment to a directory with restricted write access.

**Aliases**

**1.**
CVE-2026-25645

**2.**
GHSA-gc5v-m9x4-r6x2

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N

**Fixed Versions**

**1.**
2.33.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-2275

**2.**
https://github.com/psf/requests/releases/tag/v2.33.0

**3.**
https://github.com/psf/requests/security/advisories/GHSA-gc5v-m9x4-r6x2

**4.**
https://github.com/psf/requests/commit/66d21cb07bd6255b1280291c4f afb71803cdb3b7

**Modified**
2026-07-13T07:15:43.964902190Z

**Affected Versions**

**1.**
listed version 0.0.1

**2.**
listed version 0.10.0

**3.**
listed version 0.10.1

**4.**
listed version 0.10.2

**5.**
listed version 0.10.3

**6.**
listed version 0.10.4

**7.**
listed version 0.10.6

**8.**
listed version 0.10.7

**9.**
listed version 0.10.8

**10.**
listed version 0.11.1

**11.**
listed version 0.11.2

**12.**

listed version 0.12.0

**13.**
listed version 0.12.01

**14.**
listed version 0.12.1

**15.**
listed version 0.13.0

**16.**
listed version 0.13.1

**17.**
listed version 0.13.2

**18.**
listed version 0.13.3

**19.**
listed version 0.13.4

**20.**
listed version 0.13.5

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.33.0"}]

**Dependency Impact**

**Parent Count**
1

**Parents**

**1.**

**Id**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**Name**
traceguard-python-lab

**Install Path**

**Root Paths**

**1.**

**1.**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**2.**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Truncated**
false

**Reachability**

**Status**
UNKNOWN

**Report**

**Status**
UNKNOWN

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Target**

**Package Node Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Export Name**

**Mapping**
Python analysis unsupported

**Coverage**

**Entrypoints**
(none recorded)

**Analyzed Files**
(none recorded)

**Source Files Available**
0

**Skipped Sources**
(none recorded)

**Functions Visited**
0

**Calls Examined**
0

**Complete For Declared Entrypoints**
false

**Boundary**
Python/PyPI dependency inventory only; no Python source call analysis.

**Evidence**
(none recorded)

**Gaps**

**1.**

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Limitations**

**1.**
Python reachability is unsupported and remains UNKNOWN. No Python source, imports, build backend, or package scripts are executed.

**Exploitability**
NOT ASSESSED

**3.**

**Id**
F-003

**Package**

**Id**
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

**Ecosystem**
PyPI

**Name**
certifi

**Version**
2024.7.4

**Project**
poetry.lock

**Install Path**
poetry/certifi@2024.7.4#2

**Is Project**
false

**Direct**
false

**Transitive**
true

**Advisory Eligible**
true

**Version Evidence**

lockfile

**What Is Wrong**
OSV returned 2 advisory ID(s) for certifi@2024.7.4 at this installed location.

**Why It Matters**
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

**Advisories**

**1.**

**Id**
GHSA-6q48-6c7w-9gw2

**Source**
https://api.osv.dev/v1/vulns/GHSA-6q48-6c7w-9gw2

**Verification**
verified

**Summary**
certifi bundles emSign root CAs with compromised intermediate CA keys

**Description**
Certifi versions before 2026.10.18 include the `emSign ECC Root CA - G3` root certificate in their bundled CA store. Eight eMudhra intermediate CA certificates that chain to this root have compromised private keys and the CA has revoked them.

An attacker with one of the compromised keys can issue valid-looking certificates for any hostname. If the attacker is also on-path, they can intercept or modify TLS traffic from clients that trust the certifi bundle. Examples include `requests`, `urllib3` and `pip`, and the Python.org macOS installer.

Certifi 2026.10.18 removed all emSign roots from the bundle. Certifi 2026.10.19 restored the emSign roots that are not affected. Upgrade to 2026.10.19 or later, and rebuild container images that vendor certifi.

**Aliases**

**1.**
PYSEC-2026-4320

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
2026.10.18

**References**

**1.**
https://osv.dev/vulnerability/GHSA-6q48-6c7w-9gw2

**2.**
https://github.com/certifi/python-certifi/security/advisories/GHS A-6q48-6c7w-9gw2

**3.**
https://discuss.python.org/t/information-for-python-users-regardi ng-emudhra-emsign-ca-certificate-security-incident/109576

**4.**
https://emudhra.we-have-a-problem.com/

**5.**
https://github.com/certifi/python-certifi

**Modified**
2026-10-26T16:15:35.371128995Z

**Severity Label**
CRITICAL

**Affected Versions**

**1.**
listed version 2019.11.28

**2.**
listed version 2019.3.9

**3.**
listed version 2019.6.16

**4.**
listed version 2019.9.11

**5.**
listed version 2020.11.8

**6.**
listed version 2020.12.5

**7.**
listed version 2020.4.5

**8.**
listed version 2020.4.5.1

**9.**
listed version 2020.4.5.2

**10.**
listed version 2020.6.20

**11.**
listed version 2021.10.8

**12.**
listed version 2021.5.30

**13.**
listed version 2022.12.7

**14.**
listed version 2022.5.18

**15.**
listed version 2022.5.18.1

**16.**
listed version 2022.6.15

**17.**
listed version 2022.6.15.1

**18.**
listed version 2022.6.15.2

**19.**
listed version 2022.9.14

**20.**
listed version 2022.9.24

**21.**
ECOSYSTEM: [{"introduced":"2019.03.09"},{"fixed":"2026.10.18"}]

**2.**

**Id**
PYSEC-2026-4320

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-4320

**Verification**
verified

**Summary**
certifi bundles emSign root CAs with compromised intermediate CA keys

**Description**
Certifi versions before 2026.10.18 include the `emSign ECC Root CA - G3` root certificate in their bundled CA store. Eight

eMudhra intermediate CA certificates that chain to this root have compromised private keys and the CA has revoked them.

An attacker with one of the compromised keys can issue valid-looking certificates for any hostname. If the attacker is also on-path, they can intercept or modify TLS traffic from clients that trust the certifi bundle. Examples include `requests`, `urllib3` and `pip`, and the Python.org macOS installer.

Certifi 2026.10.18 removed all emSign roots from the bundle. Certifi 2026.10.19 restored the emSign roots that are not affected. Upgrade to 2026.10.19 or later, and rebuild container images that vendor certifi.

**Aliases**

**1.**
GHSA-6q48-6c7w-9gw2

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
2026.10.18

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-4320

**2.**
https://github.com/certifi/python-certifi/security/advisories/GHS A-6q48-6c7w-9gw2

**3.**
https://discuss.python.org/t/information-for-python-users-regardi ng-emudhra-emsign-ca-certificate-security-incident/109576

**4.**
https://emudhra.we-have-a-problem.com/

**5.**
https://github.com/certifi/python-certifi

**6.**
https://pypi.org/project/certifi

**7.**
https://github.com/advisories/GHSA-6q48-6c7w-9gw2

**Modified**
2026-10-30T14:00:02.590922333Z

**Affected Versions**

**1.**
listed version 2019.11.28

**2.**
listed version 2019.3.9

**3.**
listed version 2019.6.16

**4.**
listed version 2019.9.11

**5.**
listed version 2020.11.8

**6.**
listed version 2020.12.5

**7.**
listed version 2020.4.5

**8.**
listed version 2020.4.5.1

**9.**
listed version 2020.4.5.2

**10.**
listed version 2020.6.20

**11.**
listed version 2021.10.8

**12.**
listed version 2021.5.30

**13.**
listed version 2022.12.7

**14.**
listed version 2022.5.18

**15.**
listed version 2022.5.18.1

**16.**
listed version 2022.6.15

**17.**
listed version 2022.6.15.1

**18.**
listed version 2022.6.15.2

**19.**
listed version 2022.9.14

**20.**
listed version 2022.9.24

**21.**
ECOSYSTEM: [{"introduced":"2019.03.09"},{"fixed":"2026.10.18"}]

**Dependency Impact**

**Parent Count**
1

**Parents**

**1.**

**Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Name**
requests

**Version**
2.31.0

**Install Path**
poetry/requests@2.31.0#1

**Root Paths**

**1.**

**1.**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**2.**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**3.**
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

**Truncated**
false

**Reachability**

**Status**
UNKNOWN

**Report**

**Status**
UNKNOWN

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Target**

**Package Node Id**
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

**Export Name**

**Mapping**
Python analysis unsupported

**Coverage**

**Entrypoints**
(none recorded)

**Analyzed Files**
(none recorded)

**Source Files Available**
0

**Skipped Sources**
(none recorded)

**Functions Visited**
0

**Calls Examined**
0

**Complete For Declared Entrypoints**
false

**Boundary**
Python/PyPI dependency inventory only; no Python source call analysis.

**Evidence**
(none recorded)

**Gaps**

**1.**

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Limitations**

**1.**
Python reachability is unsupported and remains UNKNOWN. No Python source, imports, build backend, or package scripts are executed.

**Exploitability**
NOT ASSESSED

**4.**

**Id**
F-004

**Package**

**Id**
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

**Ecosystem**
PyPI

**Name**
idna

**Version**
3.7

**Project**
poetry.lock

**Install Path**
poetry/idna@3.7#4

**Is Project**
false

**Direct**
false

**Transitive**
true

**Advisory Eligible**
true

**Version Evidence**
lockfile

**What Is Wrong**
OSV returned 2 advisory ID(s) for idna@3.7 at this installed location.

**Why It Matters**
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

**Advisories**

**1.**

**Id**
GHSA-65pc-fj4g-8rjx

**Source**
https://api.osv.dev/v1/vulns/GHSA-65pc-fj4g-8rjx

**Verification**
verified

**Summary**
Internationalized Domain Names in Applications (IDNA): Specially crafted inputs to idna.encode() can bypass CVE-2024-3651 fix

**Description**
This is the same issue as CVE-2024-3651, however the original remediation in 2024 was not a complete fix. Payloads such as `'"\u0660" * N` or `'"\u30fb" * N + "\u6f22"'` utilize the `valid_contexto` function prior to length rejection, and for high values of `N` will take a long time to process.

### Impact
A specially crafted argument to the `idna.encode()` function could consume significant resources. This may lead to a denial-of-service.

### Patches
Starting in version 3.14, the function rejects long inputs as soon as practicable prior to any further processing to minimize resource consumption. In version 3.15, this approach was extended to lesser used alternate functions (i.e. per-label conversions and codec support).

### Workarounds
Domain names cannot exceed 253 characters in length, if this length limit is enforced prior to passing the domain to the `idna.encode()` function it should no longer consume significant resources. This is triggered by arbitrarily large inputs that would not occur in normal usage, but may be passed to the library assuming there is no preliminary input validation by the higher-level application.

**Aliases**

**1.**
CVE-2026-45409

**2.**
PYSEC-2026-215

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

**2.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
3.15

**References**

**1.**
https://osv.dev/vulnerability/GHSA-65pc-fj4g-8rjx

**2.**
https://github.com/kjd/idna/security/advisories/GHSA-65pc-fj4g-8rjx

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-45409

**4.**
https://github.com/kjd/idna

**5.**
https://github.com/pypa/advisory-database/tree/main/vulns/idna/PY SEC-2026-215.yaml

**Modified**
2026-09-10T03:50:45.700124422Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 0.1

**2.**
listed version 0.2

**3.**
listed version 0.3

**4.**
listed version 0.4

**5.**
listed version 0.5

**6.**
listed version 0.6

**7.**
listed version 0.7

**8.**
listed version 0.8

**9.**
listed version 0.9

**10.**
listed version 1.0

**11.**
listed version 1.1

**12.**
listed version 2.0

**13.**
listed version 2.1

**14.**
listed version 2.10

**15.**
listed version 2.2

**16.**
listed version 2.3

**17.**
listed version 2.4

**18.**
listed version 2.5

**19.**
listed version 2.6

**20.**
listed version 2.7

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"3.15"}]

**2.**

**Id**
PYSEC-2026-215

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-215

**Verification**
verified

**Summary**
OSV advisory matches the recorded package version.

**Description**
Internationalized Domain Names in Applications (IDNA) for Python provides support for Internationalized Domain Names in Applications (IDNA) and Unicode IDNA Compatibility Processing. In versions prior to 3.15, payloads such as `"\u0660" * N` or `"\u30fb" * N + "\u6f22"` utilize the `valid_contexto` function prior to length rejection, and for high values of `N` will take a long time to process. This is the same issue as CVE-2024-3651, however the original remediation in 2024 was not a complete fix. A specially crafted argument to the `idna.encode()` function could consume significant resources. This may lead to a denial-of-service. Starting in version 3.14, the function rejects long inputs as soon as practicable prior to any further processing to minimize resource consumption. In version 3.15, this approach was extended to lesser used alternate functions (i.e. per-label conversions and codec support). A workaround is available. Domain names cannot exceed 253 characters in length. If this length limit is enforced prior to passing the domain to the `idna.encode()` function, it should no longer consume significant resources. This is triggered by arbitrarily large inputs that would not occur in normal usage, but may be passed to the library assuming there is no preliminary input validation by the higher-level application.

**Aliases**

**1.**
CVE-2026-45409

**2.**
GHSA-65pc-fj4g-8rjx

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

**Fixed Versions**

**1.**
3.15

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-215

**2.**
https://github.com/kjd/idna/security/advisories/GHSA-65pc-fj4g-8rjx

**Modified**
2026-06-16T16:15:04.639265054Z

**Affected Versions**

**1.**
listed version 0.1

**2.**
listed version 0.2

**3.**
listed version 0.3

**4.**
listed version 0.4

**5.**
listed version 0.5

**6.**
listed version 0.6

**7.**
listed version 0.7

**8.**
listed version 0.8

**9.**
listed version 0.9

**10.**
listed version 1.0

**11.**
listed version 1.1

**12.**
listed version 2.0

**13.**
listed version 2.1

**14.**
listed version 2.10

**15.**
listed version 2.2

**16.**
listed version 2.3

**17.**
listed version 2.4

**18.**
listed version 2.5

**19.**
listed version 2.6

**20.**
listed version 2.7

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"3.15"}]

**Dependency Impact**

**Parent Count**
1

**Parents**

**1.**

**Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Name**
requests

**Version**
2.31.0

**Install Path**
poetry/requests@2.31.0#1

**Root Paths**

**1.**

**1.**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**2.**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**3.**
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

**Truncated**
false

**Reachability**

**Status**
UNKNOWN

**Report**

**Status**
UNKNOWN

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Target**

**Package Node Id**
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

**Export Name**

**Mapping**
Python analysis unsupported

**Coverage**

**Entrypoints**
(none recorded)

**Analyzed Files**
(none recorded)

**Source Files Available**
0

**Skipped Sources**
(none recorded)

**Functions Visited**
0

**Calls Examined**
0

**Complete For Declared Entrypoints**
false

**Boundary**
Python/PyPI dependency inventory only; no Python source call analysis.

**Evidence**
(none recorded)

**Gaps**

**1.**

**Reason**

Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Limitations**

**1.**
Python reachability is unsupported and remains UNKNOWN. No Python source, imports, build backend, or package scripts are executed.

**Exploitability**
NOT ASSESSED

**5.**

**Id**
F-005

**Package**

**Id**
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

**Ecosystem**
PyPI

**Name**
urllib3

**Version**
2.2.2

**Project**
poetry.lock

**Install Path**
poetry/urllib3@2.2.2#5

**Is Project**
false

**Direct**
false

**Transitive**
true

**Advisory Eligible**
true

**Version Evidence**
lockfile

**What Is Wrong**
OSV returned 16 advisory ID(s) for urllib3@2.2.2 at this installed location.

**Why It Matters**
The locked dependency includes a version associated with published security advisories. Dependent packages or project roots may inherit this dependency impact. The advisory preconditions and application exposure must be evaluated separately.

**Advisories**

**1.**

**Id**
GHSA-2xpw-w6gg-jr37

**Source**
https://api.osv.dev/v1/vulns/GHSA-2xpw-w6gg-jr37

**Verification**
verified

**Summary**
urllib3 streaming API improperly handles highly compressed data

**Description**
### Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.5.0/advanced-usage.html# streaming-and-i-o) is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body

into memory at once.

When streaming a compressed response, urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). The library must read compressed data from the network and decompress it until the requested chunk size is met. Any resulting decompressed data that exceeds the requested amount is held in an internal buffer for the next read operation.

The decompression logic could cause urllib3 to fully decode a small amount of highly compressed data in a single operation. This can result in excessive resource consumption (high CPU usage and massive memory allocation for the decompressed data; CWE-409) on the client side, even if the application only requested a small chunk of data.

### Affected usages

Applications and libraries using urllib3 version 2.5.0 and earlier to stream large compressed responses or content from untrusted sources.

`stream()`, `read(amt=256)`, `read1(amt=256)`, `read_chunked(amt=256)`, `readinto(b)` are examples of `urllib3.HTTPResponse` method calls using the affected logic unless decoding is disabled explicitly.

### Remediation

Upgrade to at least urllib3 v2.6.0 in which the library avoids decompressing data that exceeds the requested amount.

If your environment contains a package facilitating the Brotli encoding, upgrade to at least Brotli 1.2.0 or brotlicffi 1.2.0.0 too. These versions are enforced by the `urllib3[brotli]` extra in the patched versions of urllib3.

### Credits

The issue was reported by @Cycloctane.
Supplemental information was provided by @stamparm during a security audit performed by [7ASecurity](https://7asecurity.com/) and facilitated by [OSTIF](https://ostif.org/).

**Aliases**

**1.**
CVE-2025-66471

**2.**
PYSEC-2026-1994

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-2xpw-w6gg-jr37

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-2xpw-w6gg-jr37

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-66471

**4.**

https://github.com/urllib3/urllib3/commit/c19571de34c47de3a766541 b041637ba5f716ed7

**5.**
https://github.com/urllib3/urllib3/commit/d0fde3672e4a4093f758785 8dccfc298eb66e46c

**6.**
https://github.com/advisories/GHSA-2xpw-w6gg-jr37

**7.**
https://github.com/pypa/advisory-database/tree/main/vulns/urllib3 /PYSEC-2026-1994.yaml

**8.**
https://github.com/urllib3/urllib3

**9.**
https://pypi.org/project/urllib3

**Modified**
2026-09-25T17:15:05.968189421Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.0

**2.**
listed version 1.0.1

**3.**
listed version 1.0.2

**4.**
listed version 1.1

**5.**
listed version 1.10

**6.**
listed version 1.10.1

**7.**
listed version 1.10.2

**8.**
listed version 1.10.3

**9.**
listed version 1.10.4

**10.**
listed version 1.11

**11.**
listed version 1.12

**12.**
listed version 1.13

**13.**
listed version 1.13.1

**14.**
listed version 1.14

**15.**
listed version 1.15

**16.**
listed version 1.15.1

**17.**
listed version 1.16

**18.**
listed version 1.17

**19.**
listed version 1.18

**20.**
listed version 1.18.1

**21.**
ECOSYSTEM: [{"introduced":"1.0"},{"fixed":"2.6.0"}]

**2.**

**Id**
GHSA-38jv-5279-wg99

**Source**
https://api.osv.dev/v1/vulns/GHSA-38jv-5279-wg99

**Verification**
verified

**Summary**
Decompression-bomb safeguards bypassed when following HTTP redirects (streaming API)

**Description**
### Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.6.2/advanced-usage.html# streaming-and-i-o) is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once.

urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). When using the streaming API, the library decompresses only the necessary bytes, enabling partial content consumption.

However, for HTTP redirect responses, the library would read the entire response body to drain the connection and decompress the content unnecessarily. This decompression occurred even before any read methods were called, and configured read limits did not restrict the amount of decompressed data. As a result, there was no safeguard against decompression bombs. A malicious server could exploit this to trigger excessive resource consumption on the client (high CPU usage and large memory allocations for decompressed data; CWE-409).

### Affected usages

Applications and libraries using urllib3 version 2.6.2 and earlier to stream content from untrusted sources by setting `preload_content=False` when they do not disable redirects.

### Remediation

Upgrade to at least urllib3 v2.6.3 in which the library does not decode content of redirect responses when `preload_content=False`.

If upgrading is not immediately possible, disable [redirects](https://urllib3.readthedocs.io/en/2.6.2/user-guide.ht ml#retrying-requests) by setting `redirect=False` for requests to untrusted source.

**Aliases**

**1.**
CVE-2026-21441

**2.**
PYSEC-2026-1996

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

**2.**

**Type**

CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.3

**References**

**1.**
https://osv.dev/vulnerability/GHSA-38jv-5279-wg99

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-38jv-5279-wg99

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-21441

**4.**
https://github.com/urllib3/urllib3/commit/8864ac407bba8607950025e 0979c4c69bc7abc7b

**5.**
https://github.com/urllib3/urllib3

**6.**
https://lists.debian.org/debian-lts-announce/2026/01/msg00017.html

**Modified**
2026-09-10T03:50:32.562010895Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.22

**2.**
listed version 1.23

**3.**
listed version 1.24

**4.**
listed version 1.24.1

**5.**
listed version 1.24.2

**6.**
listed version 1.24.3

**7.**
listed version 1.25

**8.**
listed version 1.25.1

**9.**
listed version 1.25.10

**10.**
listed version 1.25.11

**11.**
listed version 1.25.2

**12.**
listed version 1.25.3

**13.**
listed version 1.25.4

**14.**
listed version 1.25.5

**15.**
listed version 1.25.6

**16.**
listed version 1.25.7

**17.**
listed version 1.25.8

**18.**
listed version 1.25.9

**19.**
listed version 1.26.0

**20.**
listed version 1.26.1

**21.**
ECOSYSTEM: [{"introduced":"1.22"},{"fixed":"2.6.3"}]

**3.**

**Id**
GHSA-48p4-8xcf-vxj5

**Source**
https://api.osv.dev/v1/vulns/GHSA-48p4-8xcf-vxj5

**Verification**
verified

**Summary**
urllib3 does not control redirects in browsers and Node.js

**Description**
urllib3 [supports](https://urllib3.readthedocs.io/en/2.4.0/reference/cont rib/emscripten.html) being used in a Pyodide runtime utilizing the [JavaScript Fetch API](https://developer.mozilla.org/en-US/docs/Web/API/Fetch_API) or falling back on [XMLHttpRequest](https://developer.mozilla.org/en-US/docs/Web/API /XMLHttpRequest). This means you can use Python libraries to make HTTP requests from your browser or Node.js. Additionally, urllib3 provides [a mechanism](https:// urllib3.readthedocs.io/en/2.4.0/user-guide.htm l#retrying-requests) to control redirects.

However, the `retries` and `redirect` parameters are ignored with Pyodide; the runtime itself determines redirect behavior.

## Affected usages

Any code which relies on urllib3 to control the number of redirects for an HTTP request in a Pyodide runtime.

## Impact

Redirects are often used to exploit SSRF vulnerabilities. An application attempting to mitigate SSRF or open redirect vulnerabilities by disabling redirects may remain vulnerable if a Pyodide runtime redirect mechanism is unsuitable.

## Remediation

If you use urllib3 in Node.js, upgrade to a patched version of urllib3.

Unfortunately, browsers provide no suitable way which urllib3 can use: `XMLHttpRequest` provides no control over redirects, the Fetch API returns `opaqueredirect` responses lacking data when redirects are controlled manually. Expect default browser behavior for redirects.

**Aliases**

**1.**
CVE-2025-50182

**2.**
PYSEC-2026-1997

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.5.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-48p4-8xcf-vxj5

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-48p4-8xcf-vxj5

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-50182

**4.**
https://github.com/urllib3/urllib3/commit/7eb4a2aafe49a279c29b6d1 f0ed0f42e9736194f

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.5.0

**Modified**
2026-09-10T03:50:24.821170285Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 2.2.0

**2.**
listed version 2.2.1

**3.**
listed version 2.2.2

**4.**
listed version 2.2.3

**5.**
listed version 2.3.0

**6.**
listed version 2.4.0

**7.**
ECOSYSTEM: [{"introduced":"2.2.0"},{"fixed":"2.5.0"}]

**4.**

**Id**
GHSA-8988-9cw3-xx77

**Source**
https://api.osv.dev/v1/vulns/GHSA-8988-9cw3-xx77

**Verification**
verified

**Summary**
urllib3: HTTPS proxy TLS configuration may be ignored or overridden

**Description**
## Impact

urllib3 supports configuring TLS independently for an HTTPS proxy and the target server.

`proxy_ssl_context`, `proxy_assert_hostname`, and `proxy_assert_fingerprint` configure the TLS connection to the proxy.

`ssl_context` and the other target-specific TLS parameters configure the connection to the target server.

In urllib3 versions 1.26.0 through 2.7.0, these configurations were not consistently separated. Depending on the proxy mode, urllib3 could:

1. Ignore `proxy_ssl_context` and use the target server's SSL context for the TLS connection to an HTTPS forwarding proxy.
2. Override the HTTPS proxy's certificate-verification policy with the target server's certificate-verification policy.
3. Apply target-specific SNI, hostname assertions, certificate fingerprint assertions, or TLS client credentials to the TLS connection to an HTTPS forwarding proxy.

In particular, configuring `cert_reqs="CERT_NONE"` for a target server could overwrite the `verify_mode` of the SSL context configured for the HTTPS proxy. This modification occurred in place and persisted on the context object, potentially disabling proxy certificate verification for later connections that reused the same context.

An attacker able to intercept the connection to an HTTPS proxy may be able to impersonate the proxy when the effective proxy TLS configuration disables certificate verification or otherwise accepts the attacker's certificate. This may occur, for example, when the target server's trust or identity policy is incorrectly applied to the proxy connection.

When HTTPS forwarding is enabled, an impersonated proxy can observe or modify forwarded requests and responses, potentially exposing credentials, authentication tokens, request bodies, response data, and other sensitive information.

A TLS client certificate intended for the target server may also be presented to the proxy or to an attacker impersonating it. This can disclose the client's identity and provide proof of possession of the corresponding private key. The private key itself is not transmitted during the TLS handshake.

In CONNECT tunneling mode, impersonating the HTTPS proxy does not by itself defeat the separate end-to-end TLS connection between the client and the target server.

## Affected Usages

Code using urllib3 versions 1.26.0 through 2.7.0 may be affected in any of the following cases.

### 1. The target SSL context is used for an HTTPS forwarding proxy

HTTPS requests are forwarded through an HTTPS proxy with `use_forwarding_for_https=True`, and `proxy_ssl_context` is configured for the proxy.

urllib3 may ignore `proxy_ssl_context` and use the target server's `ssl_context` for the proxy TLS handshake. The proxy may therefore be verified using the target server's trust and certificate policy instead of the policy explicitly configured for the proxy.

### 2. The target verification policy overrides the proxy policy

An HTTPS proxy is configured with `proxy_ssl_context`, while the target ser

**Aliases**

**1.**
CVE-2026-97687

**2.**
PYSEC-2026-4175

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
2.8.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-8988-9cw3-xx77

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-8988-9cw3-xx77

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-97687

**4.**
https://github.com/urllib3/urllib3/pull/5093

**5.**
https://github.com/urllib3/urllib3/commit/07408cec79d1856d81bb42c 74a904a24fdb9e465

**6.**
https://github.com/urllib3/urllib3/commit/b6447295fff7b38fdffc67e 0df9712d60cef3cc3

**7.**
https://github.com/urllib3/urllib3

**8.**
https://github.com/urllib3/urllib3/releases/tag/2.8.0

**Modified**
2026-10-01T17:55:53.793608550Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.26.0

**2.**
listed version 1.26.1

**3.**
listed version 1.26.10

**4.**
listed version 1.26.11

**5.**
listed version 1.26.12

**6.**
listed version 1.26.13

**7.**
listed version 1.26.14

**8.**
listed version 1.26.15

**9.**
listed version 1.26.16

**10.**
listed version 1.26.17

**11.**
listed version 1.26.18

**12.**
listed version 1.26.19

**13.**
listed version 1.26.2

**14.**
listed version 1.26.20

**15.**
listed version 1.26.3

**16.**
listed version 1.26.4

**17.**
listed version 1.26.5

**18.**
listed version 1.26.6

**19.**
listed version 1.26.7

**20.**
listed version 1.26.8

**21.**
ECOSYSTEM: [{"introduced":"1.26.0"},{"fixed":"2.8.0"}]

**5.**

**Id**
GHSA-gm62-xv2j-4w53

**Source**
https://api.osv.dev/v1/vulns/GHSA-gm62-xv2j-4w53

**Verification**
verified

**Summary**
urllib3 allows an unbounded number of links in the decompression chain

**Description**
## Impact

urllib3 supports chained HTTP encoding algorithms for response content according to RFC 9110 (e.g., `Content-Encoding: gzip, zstd`).

However, the number of links in the decompression chain was unbounded allowing a malicious server to insert a virtually unlimited number of compression steps leading to high CPU usage and massive memory allocation for the decompressed data.

## Affected usages

Applications and libraries using urllib3 version 2.5.0 and earlier for HTTP requests to untrusted sources unless they disable content decoding explicitly.

## Remediation

Upgrade to at least urllib3 v2.6.0 in which the library limits the number of links to 5.

If upgrading is not immediately possible, use [`preload_content=False`](https://urllib3.readthedocs.io/en/2.5.0 /advanced-usage.html#streaming-and-i-o) and ensure that `resp.headers["content-encoding"]` contains a safe number of encodings before reading the response content.

**Aliases**

**1.**
CVE-2025-66418

**2.**
PYSEC-2026-1998

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-gm62-xv2j-4w53

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-gm62-xv2j-4w53

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-66418

**4.**
https://github.com/urllib3/urllib3/commit/24d7b67eac89f94e1100342 4bcf0d8f7b72222a8

**5.**
https://github.com/urllib3/urllib3

**Modified**
2026-09-10T03:50:58.741847479Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.24

**2.**
listed version 1.24.1

**3.**
listed version 1.24.2

**4.**
listed version 1.24.3

**5.**
listed version 1.25

**6.**
listed version 1.25.1

**7.**
listed version 1.25.10

**8.**
listed version 1.25.11

**9.**
listed version 1.25.2

**10.**
listed version 1.25.3

**11.**
listed version 1.25.4

**12.**
listed version 1.25.5

**13.**
listed version 1.25.6

**14.**
listed version 1.25.7

**15.**
listed version 1.25.8

**16.**
listed version 1.25.9

**17.**
listed version 1.26.0

**18.**
listed version 1.26.1

**19.**
listed version 1.26.10

**20.**
listed version 1.26.11

**21.**
ECOSYSTEM: [{"introduced":"1.24"},{"fixed":"2.6.0"}]

**6.**

**Id**
GHSA-pq67-6m6q-mj2v

**Source**
https://api.osv.dev/v1/vulns/GHSA-pq67-6m6q-mj2v

**Verification**
verified

**Summary**
urllib3 redirects are not disabled when retries are disabled on PoolManager instantiation

**Description**
urllib3 handles redirects and retries using the same mechanism, which is controlled by the `Retry` object. The most common way to disable redirects is at the request level, as follows:

```python
resp = urllib3.request("GET", "https://httpbin.org/redirect/1", redirect=False)
print(resp.status)
# 302
```

However, it is also possible to disable redirects, for all requests, by instantiating a `PoolManager` and specifying `retries` in a way that disable redirects:

```python
import urllib3

http = urllib3.PoolManager(retries=0)  # should raise MaxRetryError on redirect
http = urllib3.PoolManager(retries=urllib3.Retry(redirect=0))  # equivalent to the above
http = urllib3.PoolManager(retries=False)  # should return the first response

resp = http.request("GET", "https://httpbin.org/redirect/1")
```

However, the `retries` parameter is currently ignored, which means all the above examples don't disable redirects.

## Affected usages

Passing `retries` on `PoolManager` instantiation to disable redirects or restrict their number.

By default, requests and botocore users are not affected.

## Impact

Redirects are often used to exploit SSRF vulnerabilities. An application attempting to mitigate SSRF or open redirect vulnerabilities by disabling redirects at the PoolManager level will remain vulnerable.

## Remediation

You can remediate this vulnerability with the following steps:

 * Upgrade to a patched version of urllib3. If your organization would benefit from the continued support of urllib3 1.x, please contact [sethmichaellarson@gmail.com](mailto:sethmichaellarson@gmail.com) to discuss sponsorship or contribution opportunities.

* Disable redirects at the `request()` level instead of the `PoolManager()` level.

**Aliases**

**1.**
CVE-2025-50181

**2.**
PYSEC-2026-1999

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.5.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-pq67-6m6q-mj2v

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-pq67-6m6q-mj2v

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-50181

**4.**
https://github.com/urllib3/urllib3/commit/f05b1329126d5be6de501f9 d1e3e36738bc08857

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.5.0

**Modified**
2026-09-10T03:50:25.299291456Z

**Severity Label**
MODERATE

**Affected Versions**

**1.**
listed version 0.2

**2.**
listed version 0.3

**3.**
listed version 0.3.1

**4.**
listed version 0.4.0

**5.**
listed version 0.4.1

**6.**
listed version 1.0

**7.**
listed version 1.0.1

**8.**
listed version 1.0.2

**9.**
listed version 1.1

**10.**
listed version 1.10

**11.**
listed version 1.10.1

**12.**
listed version 1.10.2

**13.**
listed version 1.10.3

**14.**
listed version 1.10.4

**15.**
listed version 1.11

**16.**
listed version 1.12

**17.**
listed version 1.13

**18.**
listed version 1.13.1

**19.**
listed version 1.14

**20.**
listed version 1.15

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.5.0"}]

**7.**

**Id**
GHSA-qccp-gfcp-xxvc

**Source**
https://api.osv.dev/v1/vulns/GHSA-qccp-gfcp-xxvc

**Verification**
verified

**Summary**
urllib3: Sensitive headers forwarded across origins in proxied low-level redirects

**Description**
### Impact

When following cross-origin redirects for requests made using urllib3?s high-level APIs, such as `urllib3.request()`, `PoolManager.request()`, and `ProxyManager.request()`, sensitive headers ? `Authorization`, `Cookie`, and `Proxy-Authorization` (defined in `Retry.DEFAULT_REMOVE_HEADERS_ON_REDIRECT`) ? are stripped by default, as expected.

However, cross-origin redirects followed from the low-level API via `ProxyManager.connection_from_url().urlopen(..., assert_same_host=False)` still forward these sensitive headers.

### Affected usage

Applications and libraries using urllib3 versions earlier than 2.7.0 may be affected if they allow cross-origin redirects while making requests through `HTTPConnection.urlopen()` instances created via `ProxyManager.connection_from_url()`.

### Remediation

Upgrade to urllib3 version 2.7.0 or later, in which sensitive headers are stripped from redirects followed by `HTTPConnection`.

If upgrading is not immediately possible, avoid using this low-level redirect flow for cross-origin redirects. If appropriate for your use case, switch to `ProxyManager.request()`.

**Aliases**

**1.**
CVE-2026-44431

**2.**
PYSEC-2026-141

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

**2.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:H/AT:P/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
2.7.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-qccp-gfcp-xxvc

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-qccp-gfcp-xxvc

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-44431

**4.**
https://github.com/urllib3/urllib3

**Modified**
2026-09-10T03:50:47.272765640Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.23

**2.**
listed version 1.24

**3.**
listed version 1.24.1

**4.**
listed version 1.24.2

**5.**
listed version 1.24.3

**6.**
listed version 1.25

**7.**
listed version 1.25.1

**8.**
listed version 1.25.10

**9.**
listed version 1.25.11

**10.**
listed version 1.25.2

**11.**
listed version 1.25.3

**12.**

listed version 1.25.4

**13.**
listed version 1.25.5

**14.**
listed version 1.25.6

**15.**
listed version 1.25.7

**16.**
listed version 1.25.8

**17.**
listed version 1.25.9

**18.**
listed version 1.26.0

**19.**
listed version 1.26.1

**20.**
listed version 1.26.10

**21.**
ECOSYSTEM: [{"introduced":"1.23"},{"fixed":"2.7.0"}]

**8.**

**Id**
GHSA-vxq7-64xx-v4gw

**Source**
https://api.osv.dev/v1/vulns/GHSA-vxq7-64xx-v4gw

**Verification**
verified

**Summary**
urllib3: HTTPResponse.stream()/read_chunked() buffers an unbounded chunk-size line into memory

**Description**
## Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.7.0/advanced-usage.html# streaming-and-i-o) is designed for efficiently handling large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. When decoding a [chunked-transfer-encoded response](https://httpwg.org/specs/rfc9112.html#chunked.encoding), this API reads each chunk's size field by buffering until it sees `\n` or EOF.

A malicious HTTP server can return `Transfer-Encoding: chunked` and then send a very long run of bytes without any newline, causing the streaming client to buffer that entire run before urllib3 can reject the chunk size as invalid and allocate more memory than intended.

To fix the issue, we'll reject chunk-size fields larger than 65536 bytes, as already done in the non-streaming case, which is currently handled by the Python standard library. Note that this only applies to reading the chunk-size field, not the chunk data, which is already handled correctly. Thus, there shouldn't be any impact for non-malicious servers.

## Affected usages

Applications and libraries using urllib3 versions earlier than 2.8.0 may be affected when streaming a chunked response from untrusted sources. Specifically, this affects the [read_chunked()](https://urllib3.readthedocs.io/en/stable/referen ce/urllib3.response.html#urllib3.response.BaseHTTPResponse.read_c hunked) and [stream()](https://urllib3.readthedocs.io/en/stable/reference/url lib3.response.html#urllib3.response.BaseHTTPResponse.stream) methods of the HTTPResponse object.

This also affects requests streaming API, which uses urllib3 under the hood.

## Remediation

Upgrade to urllib3 version 2.8.0 or later, where chunk-size fields larger than 65536 will be rejected. If upgrading is not

immediately possible, consider reading the response at once using the [read()](https://urllib3.readthedocs.io/en/stable/reference/urlli b3.response.html#urllib3.response.BaseHTTPResponse.read) method.

**Aliases**

**1.**
CVE-2026-97689

**2.**
PYSEC-2026-4177

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.8.0

**References**

**1.**
https://osv.dev/vulnerability/GHSA-vxq7-64xx-v4gw

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-vxq7-64xx-v4gw

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-97689

**4.**
https://github.com/urllib3/urllib3/commit/cd770b059b543be29298ea5 c52afb0b1b090f5ed

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.8.0

**Modified**
2026-10-01T17:55:57.514829071Z

**Severity Label**
HIGH

**Affected Versions**

**1.**
listed version 1.10.3

**2.**
listed version 1.10.4

**3.**
listed version 1.11

**4.**
listed version 1.12

**5.**
listed version 1.13

**6.**
listed version 1.13.1

**7.**
listed version 1.14

**8.**
listed version 1.15

**9.**
listed version 1.15.1

**10.**

listed version 1.16

**11.**
listed version 1.17

**12.**
listed version 1.18

**13.**
listed version 1.18.1

**14.**
listed version 1.19

**15.**
listed version 1.19.1

**16.**
listed version 1.20

**17.**
listed version 1.21

**18.**
listed version 1.21.1

**19.**
listed version 1.22

**20.**
listed version 1.23

**21.**
ECOSYSTEM: [{"introduced":"1.10.3"},{"fixed":"2.8.0"}]

**9.**

**Id**
PYSEC-2026-141

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-141

**Verification**
verified

**Summary**
OSV advisory matches the recorded package version.

**Description**
urllib3 is an HTTP client library for Python. From 1.23 to before 2.7.0, cross-origin redirects followed from the low-level API via ProxyManager.connection_from_url().urlopen(..., assert_same_host=False) still forward these sensitive headers. This vulnerability is fixed in 2.7.0.

**Aliases**

**1.**
CVE-2026-44431

**2.**
GHSA-qccp-gfcp-xxvc

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

**Fixed Versions**

**1.**
2.7.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-141

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-qccp-gfcp-xxvc

**Modified**
2026-05-20T09:19:20.983812Z

**Affected Versions**

**1.**
listed version 1.23

**2.**
listed version 1.24

**3.**
listed version 1.24.1

**4.**
listed version 1.24.2

**5.**
listed version 1.24.3

**6.**
listed version 1.25

**7.**
listed version 1.25.1

**8.**
listed version 1.25.10

**9.**
listed version 1.25.11

**10.**
listed version 1.25.2

**11.**
listed version 1.25.3

**12.**
listed version 1.25.4

**13.**
listed version 1.25.5

**14.**
listed version 1.25.6

**15.**
listed version 1.25.7

**16.**
listed version 1.25.8

**17.**
listed version 1.25.9

**18.**
listed version 1.26.0

**19.**
listed version 1.26.1

**20.**
listed version 1.26.10

**21.**
ECOSYSTEM: [{"introduced":"1.23"},{"fixed":"2.7.0"}]

**10.**

**Id**
PYSEC-2026-1994

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1994

**Verification**
verified

**Summary**
urllib3 streaming API improperly handles highly compressed data

**Description**
### Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.5.0/advanced-usage.html# streaming-and-i-o) is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once.

When streaming a compressed response, urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). The library must read compressed data from the network and decompress it until the requested chunk size is met. Any resulting decompressed data that exceeds the requested amount is held in an internal buffer for the next read operation.

The decompression logic could cause urllib3 to fully decode a small amount of highly compressed data in a single operation. This can result in excessive resource consumption (high CPU usage and massive memory allocation for the decompressed data; CWE-409) on the client side, even if the application only requested a small chunk of data.

### Affected usages

Applications and libraries using urllib3 version 2.5.0 and earlier to stream large compressed responses or content from untrusted sources.

`stream()`, `read(amt=256)`, `read1(amt=256)`, `read_chunked(amt=256)`, `readinto(b)` are examples of `urllib3.HTTPResponse` method calls using the affected logic unless decoding is disabled explicitly.

### Remediation

Upgrade to at least urllib3 v2.6.0 in which the library avoids decompressing data that exceeds the requested amount.

If your environment contains a package facilitating the Brotli encoding, upgrade to at least Brotli 1.2.0 or brotlicffi 1.2.0.0 too. These versions are enforced by the `urllib3[brotli]` extra in the patched versions of urllib3.

### Credits

The issue was reported by @Cycloctane.
Supplemental information was provided by @stamparm during a security audit performed by [7ASecurity](https://7asecurity.com/) and facilitated by [OSTIF](https://ostif.org/).

**Aliases**

**1.**
CVE-2025-66471

**2.**
GHSA-2xpw-w6gg-jr37

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.0

**References**

**1.**

https://osv.dev/vulnerability/PYSEC-2026-1994

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-2xpw-w6gg-jr37

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-66471

**4.**
https://github.com/urllib3/urllib3/commit/c19571de34c47de3a766541 b041637ba5f716ed7

**5.**
https://github.com/urllib3/urllib3

**6.**
https://pypi.org/project/urllib3

**7.**
https://github.com/advisories/GHSA-2xpw-w6gg-jr37

**Modified**
2026-07-07T17:48:15.379954669Z

**Affected Versions**

**1.**
listed version 1.0

**2.**
listed version 1.0.1

**3.**
listed version 1.0.2

**4.**
listed version 1.1

**5.**
listed version 1.10

**6.**
listed version 1.10.1

**7.**
listed version 1.10.2

**8.**
listed version 1.10.3

**9.**
listed version 1.10.4

**10.**
listed version 1.11

**11.**
listed version 1.12

**12.**
listed version 1.13

**13.**
listed version 1.13.1

**14.**
listed version 1.14

**15.**
listed version 1.15

**16.**
listed version 1.15.1

**17.**
listed version 1.16

**18.**
listed version 1.17

**19.**
listed version 1.18

**20.**
listed version 1.18.1

**21.**
ECOSYSTEM: [{"introduced":"1.0"},{"fixed":"2.6.0"}]

**11.**

**Id**
PYSEC-2026-1996

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1996

**Verification**
verified

**Summary**
Decompression-bomb safeguards bypassed when following HTTP redirects (streaming API)

**Description**
### Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.6.2/advanced-usage.html# streaming-and-i-o) is designed for the efficient handling of large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once.

urllib3 can perform decoding or decompression based on the HTTP `Content-Encoding` header (e.g., `gzip`, `deflate`, `br`, or `zstd`). When using the streaming API, the library decompresses only the necessary bytes, enabling partial content consumption.

However, for HTTP redirect responses, the library would read the entire response body to drain the connection and decompress the content unnecessarily. This decompression occurred even before any read methods were called, and configured read limits did not restrict the amount of decompressed data. As a result, there was no safeguard against decompression bombs. A malicious server could exploit this to trigger excessive resource consumption on the client (high CPU usage and large memory allocations for decompressed data; CWE-409).

### Affected usages

Applications and libraries using urllib3 version 2.6.2 and earlier to stream content from untrusted sources by setting `preload_content=False` when they do not disable redirects.

### Remediation

Upgrade to at least urllib3 v2.6.3 in which the library does not decode content of redirect responses when `preload_content=False`.

If upgrading is not immediately possible, disable [redirects](https://urllib3.readthedocs.io/en/2.6.2/user-guide.ht ml#retrying-requests) by setting `redirect=False` for requests to untrusted source.

**Aliases**

**1.**
CVE-2026-21441

**2.**
GHSA-38jv-5279-wg99

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

**2.**

**Type**

CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.3

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-1996

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-38jv-5279-wg99

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-21441

**4.**
https://github.com/urllib3/urllib3/commit/8864ac407bba8607950025e 0979c4c69bc7abc7b

**5.**
https://github.com/urllib3/urllib3

**6.**
https://lists.debian.org/debian-lts-announce/2026/01/msg00017.html

**7.**
https://pypi.org/project/urllib3

**8.**
https://github.com/advisories/GHSA-38jv-5279-wg99

**Modified**
2026-07-07T17:48:15.382053236Z

**Affected Versions**

**1.**
listed version 1.22

**2.**
listed version 1.23

**3.**
listed version 1.24

**4.**
listed version 1.24.1

**5.**
listed version 1.24.2

**6.**
listed version 1.24.3

**7.**
listed version 1.25

**8.**
listed version 1.25.1

**9.**
listed version 1.25.10

**10.**
listed version 1.25.11

**11.**
listed version 1.25.2

**12.**
listed version 1.25.3

**13.**
listed version 1.25.4

**14.**
listed version 1.25.5

**15.**
listed version 1.25.6

**16.**
listed version 1.25.7

**17.**
listed version 1.25.8

**18.**
listed version 1.25.9

**19.**
listed version 1.26.0

**20.**
listed version 1.26.1

**21.**
ECOSYSTEM: [{"introduced":"1.22"},{"fixed":"2.6.3"}]

**12.**

**Id**
PYSEC-2026-1997

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1997

**Verification**
verified

**Summary**
urllib3 does not control redirects in browsers and Node.js

**Description**
urllib3 [supports](https://urllib3.readthedocs.io/en/2.4.0/reference/cont rib/emscripten.html) being used in a Pyodide runtime utilizing the [JavaScript Fetch API](https://developer.mozilla.org/en-US/docs/Web/API/Fetch_API) or falling back on [XMLHttpRequest](https://developer.mozilla.org/en-US/docs/Web/API /XMLHttpRequest). This means you can use Python libraries to make HTTP requests from your browser or Node.js. Additionally, urllib3 provides [a mechanism](https:// urllib3.readthedocs.io/en/2.4.0/user-guide.htm l#retrying-requests) to control redirects.

However, the `retries` and `redirect` parameters are ignored with Pyodide; the runtime itself determines redirect behavior.

## Affected usages

Any code which relies on urllib3 to control the number of redirects for an HTTP request in a Pyodide runtime.

## Impact

Redirects are often used to exploit SSRF vulnerabilities. An application attempting to mitigate SSRF or open redirect vulnerabilities by disabling redirects may remain vulnerable if a Pyodide runtime redirect mechanism is unsuitable.

## Remediation

If you use urllib3 in Node.js, upgrade to a patched version of urllib3.

Unfortunately, browsers provide no suitable way which urllib3 can use: `XMLHttpRequest` provides no control over redirects, the Fetch API returns `opaqueredirect` responses lacking data when redirects are controlled manually. Expect default browser behavior for redirects.

**Aliases**

**1.**
CVE-2025-50182

**2.**
GHSA-48p4-8xcf-vxj5

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.5.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-1997

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-48p4-8xcf-vxj5

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-50182

**4.**
https://github.com/urllib3/urllib3/commit/7eb4a2aafe49a279c29b6d1 f0ed0f42e9736194f

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.5.0

**7.**
https://pypi.org/project/urllib3

**8.**
https://github.com/advisories/GHSA-48p4-8xcf-vxj5

**Modified**
2026-07-07T17:48:15.745179657Z

**Affected Versions**

**1.**
listed version 2.2.0

**2.**
listed version 2.2.1

**3.**
listed version 2.2.2

**4.**
listed version 2.2.3

**5.**
listed version 2.3.0

**6.**
listed version 2.4.0

**7.**
ECOSYSTEM: [{"introduced":"2.2.0"},{"fixed":"2.5.0"}]

**13.**

**Id**
PYSEC-2026-1998

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1998

**Verification**
verified

**Summary**
urllib3 allows an unbounded number of links in the decompression chain

**Description**

## Impact

urllib3 supports chained HTTP encoding algorithms for response content according to RFC 9110 (e.g., `Content-Encoding: gzip, zstd`).

However, the number of links in the decompression chain was unbounded allowing a malicious server to insert a virtually unlimited number of compression steps leading to high CPU usage and massive memory allocation for the decompressed data.

## Affected usages

Applications and libraries using urllib3 version 2.5.0 and earlier for HTTP requests to untrusted sources unless they disable content decoding explicitly.

## Remediation

Upgrade to at least urllib3 v2.6.0 in which the library limits the number of links to 5.

If upgrading is not immediately possible, use [`preload_content=False`](https://urllib3.readthedocs.io/en/2.5.0 /advanced-usage.html#streaming-and-i-o) and ensure that `resp.headers["content-encoding"]` contains a safe number of encodings before reading the response content.

**Aliases**

**1.**
CVE-2025-66418

**2.**
GHSA-gm62-xv2j-4w53

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.6.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-1998

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-gm62-xv2j-4w53

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-66418

**4.**
https://github.com/urllib3/urllib3/commit/24d7b67eac89f94e1100342 4bcf0d8f7b72222a8

**5.**
https://github.com/urllib3/urllib3

**6.**
https://pypi.org/project/urllib3

**7.**
https://github.com/advisories/GHSA-gm62-xv2j-4w53

**Modified**
2026-07-07T17:47:54.140852492Z

**Affected Versions**

**1.**
listed version 1.24

**2.**
listed version 1.24.1

**3.**
listed version 1.24.2

**4.**
listed version 1.24.3

**5.**
listed version 1.25

**6.**
listed version 1.25.1

**7.**
listed version 1.25.10

**8.**
listed version 1.25.11

**9.**
listed version 1.25.2

**10.**
listed version 1.25.3

**11.**
listed version 1.25.4

**12.**
listed version 1.25.5

**13.**
listed version 1.25.6

**14.**
listed version 1.25.7

**15.**
listed version 1.25.8

**16.**
listed version 1.25.9

**17.**
listed version 1.26.0

**18.**
listed version 1.26.1

**19.**
listed version 1.26.10

**20.**
listed version 1.26.11

**21.**
ECOSYSTEM: [{"introduced":"1.24"},{"fixed":"2.6.0"}]

**14.**

**Id**
PYSEC-2026-1999

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-1999

**Verification**
verified

**Summary**
urllib3 redirects are not disabled when retries are disabled on PoolManager instantiation

**Description**
urllib3 handles redirects and retries using the same mechanism, which is controlled by the `Retry` object. The most common way to disable redirects is at the request level, as follows:

```python
resp = urllib3.request("GET", "https://httpbin.org/redirect/1", redirect=False)
print(resp.status)
# 302
```

However, it is also possible to disable redirects, for all requests, by instantiating a `PoolManager` and specifying `retries` in a way that disable redirects:

```python
import urllib3

http = urllib3.PoolManager(retries=0)  # should raise MaxRetryError on redirect
http = urllib3.PoolManager(retries=urllib3.Retry(redirect=0))  # equivalent to the above
http = urllib3.PoolManager(retries=False)  # should return the first response

resp = http.request("GET", "https://httpbin.org/redirect/1")
```

However, the `retries` parameter is currently ignored, which means all the above examples don't disable redirects.

## Affected usages

Passing `retries` on `PoolManager` instantiation to disable redirects or restrict their number.

By default, requests and botocore users are not affected.

## Impact

Redirects are often used to exploit SSRF vulnerabilities. An application attempting to mitigate SSRF or open redirect vulnerabilities by disabling redirects at the PoolManager level will remain vulnerable.

## Remediation

You can remediate this vulnerability with the following steps:

 * Upgrade to a patched version of urllib3. If your organization would benefit from the continued support of urllib3 1.x, please contact [sethmichaellarson@gmail.com](mailto:sethmichaellarson@gmail.com) to discuss sponsorship or contribution opportunities.
 * Disable redirects at the `request()` level instead of the `PoolManager()` level.

**Aliases**

**1.**
CVE-2025-50181

**2.**
GHSA-pq67-6m6q-mj2v

**Severity**

**1.**

**Type**
CVSS_V3

**Score**
CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

**Fixed Versions**

**1.**
2.5.0

**References**

**1.**

https://osv.dev/vulnerability/PYSEC-2026-1999

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-pq67-6m6q-mj2v

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2025-50181

**4.**
https://github.com/urllib3/urllib3/commit/f05b1329126d5be6de501f9 d1e3e36738bc08857

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.5.0

**7.**
https://pypi.org/project/urllib3

**8.**
https://github.com/advisories/GHSA-pq67-6m6q-mj2v

**Modified**
2026-07-07T17:47:54.161376347Z

**Affected Versions**

**1.**
listed version 0.2

**2.**
listed version 0.3

**3.**
listed version 0.3.1

**4.**
listed version 0.4.0

**5.**
listed version 0.4.1

**6.**
listed version 1.0

**7.**
listed version 1.0.1

**8.**
listed version 1.0.2

**9.**
listed version 1.1

**10.**
listed version 1.10

**11.**
listed version 1.10.1

**12.**
listed version 1.10.2

**13.**
listed version 1.10.3

**14.**
listed version 1.10.4

**15.**
listed version 1.11

**16.**
listed version 1.12

**17.**
listed version 1.13

**18.**
listed version 1.13.1

**19.**
listed version 1.14

**20.**
listed version 1.15

**21.**
ECOSYSTEM: [{"introduced":"0"},{"fixed":"2.5.0"}]

**15.**

**Id**
PYSEC-2026-4175

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-4175

**Verification**
verified

**Summary**
urllib3: HTTPS proxy TLS configuration may be ignored or overridden

**Description**
## Impact

urllib3 supports configuring TLS independently for an HTTPS proxy and the target server.

`proxy_ssl_context`, `proxy_assert_hostname`, and `proxy_assert_fingerprint` configure the TLS connection to the proxy. `ssl_context` and the other target-specific TLS parameters configure the connection to the target server.

In urllib3 versions 1.26.0 through 2.7.0, these configurations were not consistently separated. Depending on the proxy mode, urllib3 could:

1. Ignore `proxy_ssl_context` and use the target server's SSL context for the TLS connection to an HTTPS forwarding proxy.
2. Override the HTTPS proxy's certificate-verification policy with the target server's certificate-verification policy.
3. Apply target-specific SNI, hostname assertions, certificate fingerprint assertions, or TLS client credentials to the TLS connection to an HTTPS forwarding proxy.

In particular, configuring `cert_reqs="CERT_NONE"` for a target server could overwrite the `verify_mode` of the SSL context configured for the HTTPS proxy. This modification occurred in place and persisted on the context object, potentially disabling proxy certificate verification for later connections that reused the same context.

An attacker able to intercept the connection to an HTTPS proxy may be able to impersonate the proxy when the effective proxy TLS configuration disables certificate verification or otherwise accepts the attacker's certificate. This may occur, for example, when the target server's trust or identity policy is incorrectly applied to the proxy connection.

When HTTPS forwarding is enabled, an impersonated proxy can observe or modify forwarded requests and responses, potentially exposing credentials, authentication tokens, request bodies, response data, and other sensitive information.

A TLS client certificate intended for the target server may also be presented to the proxy or to an attacker impersonating it. This can disclose the client's identity and provide proof of possession of the corresponding private key. The private key itself is not transmitted during the TLS handshake.

In CONNECT tunneling mode, impersonating the HTTPS proxy does not by itself defeat the separate end-to-end TLS connection between the client and the target server.

## Affected Usages

Code using urllib3 versions 1.26.0 through 2.7.0 may be affected in any of the following cases.

### 1. The target SSL context is used for an HTTPS forwarding proxy

HTTPS requests are forwarded through an HTTPS proxy with `use_forwarding_for_https=True`, and `proxy_ssl_context` is configured for the proxy.

urllib3 may ignore `proxy_ssl_context` and use the target server's `ssl_context` for the proxy TLS handshake. The proxy may therefore be verified using the target server's trust and certificate policy instead of the policy explicitly configured for the proxy.

### 2. The target verification policy overrides the proxy policy

An HTTPS proxy is configured with `proxy_ssl_context`, while the target ser

**Aliases**

**1.**
CVE-2026-97687

**2.**
GHSA-8988-9cw3-xx77

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N

**Fixed Versions**

**1.**
2.8.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-4175

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-8988-9cw3-xx77

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-97687

**4.**
https://github.com/urllib3/urllib3/pull/5093

**5.**
https://github.com/urllib3/urllib3/commit/07408cec79d1856d81bb42c 74a904a24fdb9e465

**6.**
https://github.com/urllib3/urllib3/commit/b6447295fff7b38fdffc67e 0df9712d60cef3cc3

**7.**
https://github.com/urllib3/urllib3

**8.**
https://github.com/urllib3/urllib3/releases/tag/2.8.0

**9.**
https://pypi.org/project/urllib3

**10.**
https://github.com/advisories/GHSA-8988-9cw3-xx77

**Modified**
2026-10-01T17:45:18.542387510Z

**Affected Versions**

**1.**
listed version 1.26.0

**2.**
listed version 1.26.1

**3.**
listed version 1.26.10

**4.**
listed version 1.26.11

**5.**
listed version 1.26.12

**6.**
listed version 1.26.13

**7.**
listed version 1.26.14

**8.**
listed version 1.26.15

**9.**
listed version 1.26.16

**10.**
listed version 1.26.17

**11.**
listed version 1.26.18

**12.**
listed version 1.26.19

**13.**
listed version 1.26.2

**14.**
listed version 1.26.20

**15.**
listed version 1.26.3

**16.**
listed version 1.26.4

**17.**
listed version 1.26.5

**18.**
listed version 1.26.6

**19.**
listed version 1.26.7

**20.**
listed version 1.26.8

**21.**
ECOSYSTEM: [{"introduced":"1.26.0"},{"fixed":"2.8.0"}]

**16.**

**Id**
PYSEC-2026-4177

**Source**
https://api.osv.dev/v1/vulns/PYSEC-2026-4177

**Verification**
verified

**Summary**
urllib3: HTTPResponse.stream()/read_chunked() buffers an unbounded chunk-size line into memory

**Description**
## Impact

urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.7.0/advanced-usage.html# streaming-and-i-o) is designed for efficiently handling large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. When decoding a [chunked-transfer-encoded response](https://httpwg.org/specs/rfc9112.html#chunked.encoding), this API reads each chunk's size field by buffering until it sees `\n` or EOF.

A malicious HTTP server can return `Transfer-Encoding: chunked` and then send a very long run of bytes without any newline, causing the streaming client to buffer that entire run before urllib3 can reject the chunk size as invalid and allocate more memory than intended.

To fix the issue, we'll reject chunk-size fields larger than 65536 bytes, as already done in the non-streaming case, which is currently handled by the Python standard library. Note that this only applies to reading the chunk-size field, not the chunk

data, which is already handled correctly. Thus, there shouldn't be any impact for non-malicious servers.

## Affected usages

Applications and libraries using urllib3 versions earlier than 2.8.0 may be affected when streaming a chunked response from untrusted sources. Specifically, this affects the [read_chunked()](https://urllib3.readthedocs.io/en/stable/referen ce/urllib3.response.html#urllib3.response.BaseHTTPResponse.read_c hunked) and [stream()](https://urllib3.readthedocs.io/en/stable/reference/url lib3.response.html#urllib3.response.BaseHTTPResponse.stream) methods of the HTTPResponse object.

This also affects requests streaming API, which uses urllib3 under the hood.

## Remediation

Upgrade to urllib3 version 2.8.0 or later, where chunk-size fields larger than 65536 will be rejected. If upgrading is not immediately possible, consider reading the response at once using the [read()](https://urllib3.readthedocs.io/en/stable/reference/urlli b3.response.html#urllib3.response.BaseHTTPResponse.read) method.

**Aliases**

**1.**
CVE-2026-97689

**2.**
GHSA-vxq7-64xx-v4gw

**Severity**

**1.**

**Type**
CVSS_V4

**Score**
CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:H

**Fixed Versions**

**1.**
2.8.0

**References**

**1.**
https://osv.dev/vulnerability/PYSEC-2026-4177

**2.**
https://github.com/urllib3/urllib3/security/advisories/GHSA-vxq7-64xx-v4gw

**3.**
https://nvd.nist.gov/vuln/detail/CVE-2026-97689

**4.**
https://github.com/urllib3/urllib3/commit/cd770b059b543be29298ea5 c52afb0b1b090f5ed

**5.**
https://github.com/urllib3/urllib3

**6.**
https://github.com/urllib3/urllib3/releases/tag/2.8.0

**7.**
https://pypi.org/project/urllib3

**8.**
https://github.com/advisories/GHSA-vxq7-64xx-v4gw

**Modified**
2026-10-01T17:45:18.336090182Z

**Affected Versions**

**1.**
listed version 1.10.3

**2.**
listed version 1.10.4

**3.**
listed version 1.11

**4.**
listed version 1.12

**5.**
listed version 1.13

**6.**
listed version 1.13.1

**7.**
listed version 1.14

**8.**
listed version 1.15

**9.**
listed version 1.15.1

**10.**
listed version 1.16

**11.**
listed version 1.17

**12.**
listed version 1.18

**13.**
listed version 1.18.1

**14.**
listed version 1.19

**15.**
listed version 1.19.1

**16.**
listed version 1.20

**17.**
listed version 1.21

**18.**
listed version 1.21.1

**19.**
listed version 1.22

**20.**
listed version 1.23

**21.**
ECOSYSTEM: [{"introduced":"1.10.3"},{"fixed":"2.8.0"}]

**Dependency Impact**

**Parent Count**
1

**Parents**

**1.**

**Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Name**
requests

**Version**
2.31.0

**Install Path**
poetry/requests@2.31.0#1

**Root Paths**

**1.**

**1.**
urn:traceguard:component:746a1ad179ea6d1b0ee60b106b8ceaef6600efd2 ed95fac3219e9c95452efc00

**2.**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**3.**
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

**Truncated**
false

**Reachability**

**Status**
UNKNOWN

**Report**

**Status**
UNKNOWN

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Target**

**Package Node Id**
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

**Export Name**

**Mapping**
Python analysis unsupported

**Coverage**

**Entrypoints**
(none recorded)

**Analyzed Files**
(none recorded)

**Source Files Available**
0

**Skipped Sources**
(none recorded)

**Functions Visited**
0

**Calls Examined**
0

**Complete For Declared Entrypoints**
false

**Boundary**
Python/PyPI dependency inventory only; no Python source call analysis.

**Evidence**
(none recorded)

**Gaps**

**1.**

**Reason**
Python reachability is UNKNOWN: no Python AST/call analysis is implemented. JavaScript analysis does not apply to Python.

**Limitations**

**1.**
Python reachability is unsupported and remains UNKNOWN. No Python source, imports, build backend, or package scripts are executed.

**Exploitability**
NOT ASSESSED

## Inventory Warnings

**1.**
poetry.lock: inventory is a lock snapshot; Python/platform activation, artifact hashes and lockfile freshness are not independently verified.

## Package Risk

**Checked At**
2026-10-31T22:05:23.400Z

**Coverage**

**Total**
6

**Metadata Checked**
0

**Unavailable**
0

**Skipped**
6

**Results**

**1.**

**Node Id**
urn:traceguard:component:bb86b3d2838012e8185ec413ac06bdb417c7389e 0fac7b644cbbafaab6e60255

**Name**
pyyaml

**Version**
5.3.1

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**2.**

**Node Id**
urn:traceguard:component:9640b0a9eb8bf7919af53e7008871f01055b4351 3c2cb87cc7af84b6459b2d73

**Name**
requests

**Version**
2.31.0

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**3.**

**Node Id**
urn:traceguard:component:ba9445ef23336812394d0e2b9066bdaea2871f94 76e9010d489d3d37f103f597

**Name**
certifi

**Version**
2024.7.4

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**4.**

**Node Id**
urn:traceguard:component:b5b7163d8af9c7df1c24eaa5f4e6bde1b389dcbe 787ca5c19c29ae2fdf4268c6

**Name**
charset-normalizer

**Version**
3.3.2

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**5.**

**Node Id**
urn:traceguard:component:dadae6aa4447dc7e2f2119d160e1cf52b441bbc1 1d8922de0b5c6dccda99feb0

**Name**
idna

**Version**
3.7

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**6.**

**Node Id**
urn:traceguard:component:79493d81990b4c073997e723ca5c37c9445b6682 35b217160ee150c640fe4254

**Name**
urllib3

**Version**
2.2.2

**Classification**
UNKNOWN

**Metadata Status**
skipped

**Signals**
(none recorded)

**Malicious Sources**
(none recorded)

**Integrity**

**Comparison**
NOT COMPARABLE

**Artifact Verification**
NOT PERFORMED

**Provenance**

**Status**
UNKNOWN

**Signatures**
(none recorded)

**Verification**
NOT PERFORMED

**Review Steps**

**1.**
PyPI supply-chain metadata, artifact integrity and provenance checks are not implemented. npm heuristics do not apply; this coverage is UNKNOWN.

**Limitations**

**1.**
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

**2.**
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

**3.**

At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

**4.**
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

**5.**
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

**6.**
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

**Sources**

**1.**
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

**2.**
https://docs.npmjs.com/viewing-package-provenance/

**3.**
https://docs.npmjs.com/cli/v11/commands/npm-audit/

**4.**
https://osv.dev/